

**INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY****Week 4 Assignment**

Monitoring and Auditing Security Controls*Continuous Control Monitoring and Assurance Design Project*

Course	GRC102 – Information Security Governance
Module	Module 4 – Monitoring and Auditing Security Controls
Week	Week 4: 26 September – 02 October 2026
Opens	26 September 2026, 8:00 AM WAT
Due	02 October 2026, 11:59 PM WAT
Maximum Score	100 marks
Effective Course Contribution	8.75% of final course grade

Submission mode: Combined evidence professional report with supporting control-monitoring artefacts

This assignment assesses continuous control monitoring, audit evidence, management reporting and remediation governance.

1. Assignment Overview

Security controls cannot be considered effective merely because they have been documented or implemented once. Management requires continuing evidence that controls are operating as intended, exceptions are detected promptly, failures are escalated, and remediation actions are completed and independently retested.

In this assignment, you will design a continuous security-control monitoring and audit assurance programme for a medium-sized organisation. You will determine what evidence should be collected, how frequently controls should be reviewed, which KPIs and KRIs should be reported, how technology such as SIEM and vulnerability-management platforms can support oversight, and how control failures should move from detection to verified closure.

2. Learning Outcomes

- Differentiate control design, control implementation and control operating effectiveness.
- Design a practical continuous-control monitoring register for key security controls.
- Identify reliable evidence sources and assign appropriate control owners and assurance responsibilities.
- Define measurable KPIs, KRIs, thresholds and escalation criteria.
- Explain how SIEM, system logs, vulnerability data and other security telemetry support automated oversight.
- Design a governance workflow for documenting, assigning, remediating, retesting and closing control failures.
- Translate monitoring data into management-level security assurance reporting.

3. Organisational Scenario Meridian Digital Services

Meridian Digital Services (MDS) is a medium-sized technology and managed-services organisation with approximately 800 employees. It operates a hybrid environment consisting of cloud-hosted business applications, corporate endpoints, identity services, remote-access infrastructure, centralised logging, third-party SaaS services and several business-critical databases.

Over the past year, MDS has expanded quickly. Internal audits have found that many controls exist on paper, but management cannot consistently demonstrate whether they are operating effectively. Some teams collect evidence manually, others rely on technical dashboards, and there is no single process for escalating control failures or tracking remediation to closure.

You have been appointed Security Governance and Assurance Adviser. The Chief Information Security Officer (CISO) has asked you to design a monitoring and audit assurance model that gives control owners, senior management and the Board reliable visibility into control effectiveness.

4. Task 1 Continuous Control Monitoring Register (25 marks)

Design a monitoring register covering at least ten security controls. Your controls should represent a balanced mix of preventive, detective and corrective controls.

ID	Control / Objective & Risk	Control Owner	Monitoring Owner	Evidence Source	Frequency	KPI/KRI	Target / Threshold	Escalation Trigger
CCM-01	Identity & Privileged Access Reviews — Ensure access remains appropriate and excessive privileges are removed.	IAM Manager	Security Governance / IAM Analyst	IAM reports, access review records, privileged-access logs	Monthly	% of privileged accounts reviewed	≥98% reviewed monthly	<95% or unidentified privileged account → CISO
CCM-02	MFA Coverage — Reduce risk of unauthorised access to corporate and cloud services.	IAM Manager	Security Operations	Identity platform reports, MFA dashboard, authentication logs	Weekly	% of in-scope accounts protected by MFA	≥98%	<95% → CISO and IT Manager
CCM-03	Vulnerability Remediation — Ensure	Infrastructure Manager	Vulnerability Management Lead	Vulnerability scanner reports,	Weekly	% of critical vulnerabilities remediated	≥95%	<90% or critical internet-

	vulnerabilities are identified and remediated within approved SLAs.			remediation tickets		within SLA		facing vulnerability overdue → CISO
CCM-04	Endpoint Protection / EDR — Ensure corporate endpoints are protected and reporting correctly.	Endpoint Manager	Security Operations	EDR dashboard, endpoint health reports, alert logs	Daily	% of active endpoints reporting to EDR	≥98%	<95% or critical endpoint without protection → CISO
CCM-05	Security Logging & SIEM Ingestion — Ensure security-relevant events are available for detection and investigation.	SOC Manager	SIEM Analyst	SIEM dashboards, log-source health reports, ingestion alerts	Daily	% of critical log sources successfully ingesting	≥98%	<95% or critical log source offline → SOC Manager/CISO
CCM-06	Backup & Restoration Testing — Ensure critical information can be recovered following failure or cyber incident.	Infrastructure Manager	IT Operations / Business Continuity	Backup reports, restore-test evidence, recovery logs	Daily / Quarterly testing	Backup success rate and restore-test success	≥98% backup success; 100% scheduled restore tests	Failed critical backup or failed restore test → CISO/IT Director
CCM-07	Security Patch Compliance — Reduce exposure caused by unpatched systems.	Infrastructure Manager	Endpoint / Systems Team	Patch-management dashboard, system reports	Weekly	% of critical systems patched within SLA	≥95%	<90% or critical asset outside SLA → CISO
CCM-08	Change Management — Ensure security-impacting changes are authorised and traceable.	IT Change Manager	IT Governance / Internal Control	Change tickets, approvals, emergency-change records	Monthly	% of changes with documented approval	≥98%	Unauthorised high-risk change → IT Director/CISO
CCM-09	Data Protection & Encryption — Protect sensitive data from unauthorised disclosure or inappropriate handling.	Data Protection Officer	Security / Compliance Team	Encryption reports, DLP alerts, data classification records	Monthly	% of sensitive systems meeting encryption requirements	≥98%	Unencrypted critical data store → CISO/DPO
CCM-	Security	HR Manager	Security	Training	Monthly /	Training	≥95%	<90%

10	Awareness & Phishing Resilience — Reduce human-related security risk.		Awareness Lead	records, phishing simulation results, completion reports	Quarterly	completion and phishing failure rate	completion; phishing failure ≤5%	completion or phishing failure >10% → CISO/HR
CCM-11	Cloud Security Posture — Identify and correct insecure cloud configurations.	Cloud Infrastructure Manager	Cloud Security Team	CSPM reports, cloud configuration logs, security alerts	Weekly	% of critical cloud misconfigurations remediated within SLA	≥95%	Critical exposure or <90% SLA compliance → CISO
CCM-12	Third-Party Security Assurance — Ensure material suppliers maintain appropriate security controls.	Vendor Management Manager	Risk / Third-Party Assurance	Security assessments, certifications, vendor questionnaires, contracts	Quarterly	% of critical suppliers reviewed	100% annually	Critical supplier without current assessment → CRO/CISO

The selected controls provide a balanced view of Meridian Digital Services' security posture by covering preventive, detective and corrective activities across identity, endpoints, infrastructure, data, cloud services, third parties and human behaviour. The register combines technical telemetry, management records and assurance evidence to provide continuing visibility rather than relying on one-time control implementation. The selected KPIs and KRIs allow management to identify declining performance, control exceptions and risks requiring escalation.

Control Effectiveness Approach

Control Design Effectiveness asks whether the control is appropriately designed to address the identified risk.

Control Implementation confirms that the designed control has actually been put into operation.

Control Operating Effectiveness determines whether the implemented control continues to operate as intended over time, based on reliable evidence.

For example, MDS may have an MFA policy and configuration in place. This demonstrates design and implementation. Continuous monitoring of MFA coverage and authentication data provides evidence of whether MFA remains operationally effective across the required population.

5. Task 2 Monitoring Architecture and Automation (20 marks)

Explain how security telemetry and assurance evidence can be collected and correlated to reduce dependence on manual checking.

SIEM Monitoring

The Security Information and Event Management (SIEM) platform should provide a central location for collecting, correlating and analysing security-relevant events.

The SIEM can support continuous monitoring of:

- Authentication events.
- Failed and successful login attempts.
- Privileged account activity.
- Administrative actions.

- Security alerts.
- Malware and endpoint events.
- Firewall and network events.
- Cloud security events.
- Suspicious user activity.
- Control exceptions.
- Critical system alerts.

Correlation rules can combine events from different sources to identify patterns that may not be visible when systems are reviewed individually.

For example, multiple failed authentication attempts followed by a successful privileged login and unusual administrative activity could generate an alert for investigation.

The SIEM can also provide evidence that required logging sources remain connected and actively sending data.

System and Application Logs

System and application logs provide evidence of whether security controls are operating as expected.

Examples include:

Evidence Source	Assurance Information
Identity logs	Authentication, MFA and privileged-access activity
Operating-system logs	Administrative actions and system events
Application logs	User activity and application security events
Database logs	Database access and privileged operations
Firewall logs	Network connections and security events
Cloud logs	Configuration and administrative activity
VPN logs	Remote-access activity
EDR logs	Endpoint security status and detections

Logs should have appropriate timestamps, retention periods, access restrictions and integrity protections so that they remain useful as assurance evidence.

Vulnerability-Management Data

Vulnerability-management platforms provide evidence about weaknesses identified across MDS's infrastructure and applications.

The data can be used to monitor:

- Number of critical vulnerabilities.
- Number of overdue vulnerabilities.
- Vulnerabilities by asset.
- Vulnerability age.
- Remediation SLA compliance.
- Internet-facing vulnerabilities.
- Recurring vulnerabilities.
- Exceptions and approved risk acceptances.

The vulnerability data can be linked to remediation tickets so that management can determine whether identified vulnerabilities are actually being addressed.

For example:

Vulnerability Identified

|

v

Risk Rated

|

v

Remediation Ticket

|

v

Assigned to Owner

|

v

SLA Monitoring

|

v

Remediated

|

v

Verification / Rescan

This creates a traceable connection between technical vulnerability data and management assurance.

Other Evidence Sources

Endpoint Data

Endpoint and EDR platforms can provide:

- Device protection status.
- Agent health.
- Malware detections.
- Endpoint isolation events.
- Security policy compliance.

Identity Data

Identity platforms can provide:

- MFA coverage.
- Privileged-account information.
- Authentication events.

- Access changes.
- Account status.

Cloud Security Data

Cloud security platforms can provide:

- Misconfiguration findings.
- Exposed services.
- Identity and access risks.
- Configuration changes.
- Security alerts.

Ticketing Data

IT service-management or ticketing systems can provide evidence of:

- Vulnerability remediation.
- Access approvals.
- Change approvals.
- Incident handling.
- Control exceptions.
- Corrective actions.

Linking technical evidence with ticketing information allows MDS to determine whether an identified issue has been assigned, remediated and verified.

Automated, Semi-Automated and Manual Assurance

Not every control can be completely automated. MDS should distinguish between evidence that can be collected automatically and activities that require human judgement.

Assurance Activity	Automation Level	Evidence / Method	Human Review Required
MFA coverage	Automated	Identity platform report	Exception review
EDR coverage	Automated	EDR dashboard	Investigation of unhealthy endpoints
SIEM log ingestion	Automated	SIEM health monitoring	Review of missing critical sources
Vulnerability discovery	Automated	Vulnerability scanner	Risk prioritisation and exception decisions
Patch compliance	Automated / Semi-automated	Patch-management dashboard	Review of exceptions
Backup success	Automated	Backup platform reports	Investigation of failures
Privileged-access review	Semi-automated	IAM reports and access lists	Manager validates business need
Change approvals	Semi-automated	ITSM/change-management system	Review high-risk or emergency changes
Security awareness completion	Semi-automated	Learning-management system	Follow-up with non-compliant users
Third-party security assurance	Semi-automated	Vendor assessments and documentation	Risk assessment and judgement
Cloud configuration review	Automated / Semi-automated	CSPM findings	Risk validation and remediation decisions

Risk acceptance	Manual	Risk assessment and approval record	Required executive/business-owner judgement
------------------------	--------	-------------------------------------	---

Automation and Monitoring Risks

Although automation improves consistency and speed, MDS should not assume that automated monitoring is automatically reliable.

Risk 1: Incomplete Telemetry

If important systems are not connected to the monitoring platform, management may receive an incomplete view of the security environment.

Control: Maintain an approved inventory of required log sources and monitor their ingestion status.

Risk 2: False Positives

Automated systems may generate alerts that do not represent genuine security issues.

Control: Regularly tune detection rules and investigate alert-quality metrics.

Risk 3: Stale or Failed Integrations

A monitoring integration may stop working while appearing operational.

Control: Monitor connector health, ingestion timestamps and expected data volumes.

Risk 4: Poor Data Quality

Incorrect, incomplete or duplicated data can result in inaccurate metrics.

Control: Establish data-validation checks and defined data-quality ownership.

Risk 5: Over-Reliance on Automation

Automated dashboards may identify exceptions but cannot always determine business context, risk acceptance or whether remediation is appropriate.

Control: Require human review for high-risk exceptions, risk acceptance, material decisions and assurance conclusions.

Monitoring Ownership and Reporting

Monitoring responsibilities should be distributed across the organisation.

Role	Monitoring Responsibility
Control Owner	Ensures the control operates and exceptions are addressed
Monitoring Owner	Collects and reviews evidence
Security Operations	Monitors technical security telemetry and alerts
CISO	Provides security oversight and escalation
Risk / Compliance	Provides independent challenge and risk assurance
Internal Audit	Performs independent assurance where required
Senior Management	Reviews significant trends and remediation
Board	Receives material risk and control-effectiveness information

6. Task 3 Security Control Dashboard and Management Reporting (20 marks)

Task 3: Security Control Dashboard and Management Reporting

3.1 Purpose

The Security Control Monitoring Dashboard provides senior management and the Board with a concise, evidence-based view of the effectiveness of MDS security controls.

The dashboard brings together KPIs and KRIs from the Continuous Control Monitoring Register and presents each metric against its target, current result, trend and RAG status. This enables management to identify control weaknesses, determine where escalation is required and track corrective actions.

Note: The figures presented below are illustrative because the MDS scenario does not provide actual operational monitoring results.

3.2 Security Control Monitoring Dashboard

Metric	Owner	Target	Current	Trend	RAG	Management Action
MFA Coverage	IAM Manager	≥98%	97%	↑ Improving	Amber	Complete MFA coverage for remaining users
Critical Vulnerabilities Remediated Within SLA	Infrastructure Manager	≥95%	88%	↓ Declining	Red	Prioritise overdue critical vulnerabilities
EDR Endpoint Coverage	Endpoint Manager	≥98%	99%	→ Stable	Green	Continue endpoint health monitoring
Critical SIEM Log Sources Ingesting	SOC Manager	≥98%	96%	↓ Declining	Amber	Investigate missing or delayed log sources
Backup Success Rate	Infrastructure Manager	≥98%	99%	→ Stable	Green	Continue monitoring and restore testing
Critical Systems Patch Compliance	Infrastructure Manager	≥95%	93%	↓ Declining	Amber	Prioritise systems outside patch SLA
Security Awareness Completion	HR / Security Awareness Lead	≥95%	94%	↑ Improving	Amber	Follow up with outstanding employees
Critical Cloud Findings Remediated Within SLA	Cloud Security Manager	≥95%	91%	↓ Declining	Amber	Prioritise critical cloud misconfigurations
Privileged Access Reviews Completed	IAM Manager	≥98%	99%	→ Stable	Green	Continue monthly access reviews
Critical Suppliers Reviewed	Vendor Management	100% annually	96%	↑ Improving	Amber	Complete outstanding supplier assessments

RAG Interpretation

- **Green:** Performance is within the approved target or tolerance.
- **Amber:** Performance is below or approaching the approved target and requires management attention.
- **Red:** Performance has materially breached the threshold and requires escalation and corrective action.

3.3 Operational, Executive and Board Escalation

Not every control exception requires Board attention. Escalation should consider the severity, persistence, business impact and overall risk exposure.

Operational Escalation

Operational management can normally address:

- Minor declines in control performance.
- Isolated endpoint or logging issues.
- Individual overdue remediation items.
- Small numbers of incomplete training records.

The control owner should investigate the issue and implement corrective action.

Executive Escalation

Executive attention should be considered for:

- Critical vulnerabilities outside the approved SLA.
- Significant deterioration in patch compliance.
- Major gaps in SIEM visibility.
- Repeated control failures.
- Significant cloud-security exposure.
- Persistent performance below approved thresholds.

The CISO and relevant senior management should review the issue and agree corrective actions.

Board Attention

Board-level reporting should focus on material or persistent risks, including:

- Significant exposure to critical vulnerabilities.
- Material cybersecurity incidents.
- Persistent control failures.
- Significant deterioration in the organisation's security posture.
- Risks exceeding organisational risk appetite.
- Major regulatory, financial or business impacts.

3.4 Trend-Based Observations

Observation 1: Critical Vulnerability Remediation

Critical vulnerability remediation is currently **88%**, against a target of **95%**, with a declining trend.

This indicates that remediation performance requires management attention. MDS should prioritise overdue critical vulnerabilities, particularly those affecting internet-facing and business-critical systems.

Observation 2: SIEM Visibility

Critical SIEM log-source coverage is **96%**, below the **98% target**, with a declining trend.

Reduced logging coverage may affect MDS's ability to detect and investigate security events. The SOC should identify missing or unreliable log sources and restore monitoring coverage.

Observation 3: Security Awareness

Security-awareness completion is **94%**, slightly below the **95% target**, but the trend is improving.

Management should follow up with outstanding employees while continuing the existing security-awareness programme.

3.5 Management Report

Overall Control Effectiveness

The dashboard indicates that several MDS controls are operating within their defined targets, particularly EDR coverage, backup success and privileged-access reviews.

However, several controls are below target, including vulnerability remediation, SIEM log-source coverage, patch compliance, security-awareness completion and cloud-security remediation.

The dashboard therefore provides management with both positive control indicators and areas requiring corrective action.

Three Highest-Priority Concerns

1. Critical Vulnerability Remediation

Current: 88%

Target: ≥95%

Trend: Declining

Recommended management action: Prioritise overdue critical vulnerabilities and require regular reporting until remediation performance returns to the approved target.

2. SIEM Log Visibility

Current: 96%

Target: ≥98%

Trend: Declining

Recommended management action: Identify missing or unreliable log sources and restore complete monitoring coverage.

3. Patch and Cloud Security Compliance

Patch compliance: 93%

Cloud remediation: 91%

Target: ≥95%

Both indicators are below target and show a declining trend.

Recommended management action: Review the causes of delayed remediation, assign accountable owners and monitor progress through the security governance process.

3.6 Recommended Management Actions

Priority	Action	Owner	Expected Outcome
High	Reduce overdue critical vulnerabilities	Infrastructure Manager	Remediation returns to ≥95%
High	Restore missing SIEM log sources	SOC Manager	Critical logging coverage reaches ≥98%
High	Improve patch and cloud remediation	Infrastructure / Cloud Security Managers	Security exposure reduced
Medium	Complete outstanding awareness training	HR / Security Awareness Lead	Completion reaches ≥95%
Medium	Complete outstanding supplier reviews	Vendor Management	Critical supplier assurance reaches 100%

3.7 Dashboard Reporting Principles

The dashboard should be reviewed regularly and should focus on information that supports management decision-making.

Management reporting should:

- Compare actual performance against approved targets.
- Highlight trends rather than reporting only current values.
- Identify persistent control weaknesses.
- Link exceptions to accountable owners.
- Distinguish operational issues from material risks.
- Track corrective actions to completion.
- Escalate significant risks through established governance channels.

3.8 Expected Outcome

The dashboard provides MDS management with a concise view of security-control effectiveness and highlights areas requiring corrective action or escalation.

By combining current performance, targets, trends and RAG status, MDS can move beyond simply reporting security data and use monitoring information to support risk-based management decisions.

The dashboard should be updated using validated monitoring evidence and reviewed regularly by control owners, security management and the appropriate governance bodies.

7. Task 4 Control Failure, Remediation and Retesting Workflow (20 marks)

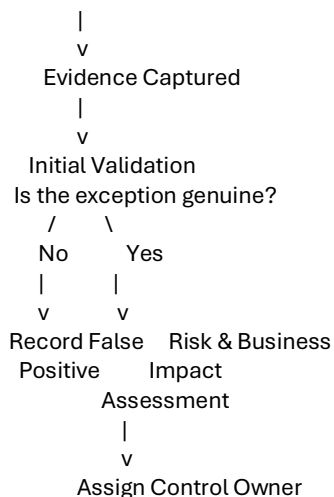
Design the governed workflow that MDS should follow when a control fails, falls below threshold or produces insufficient evidence.

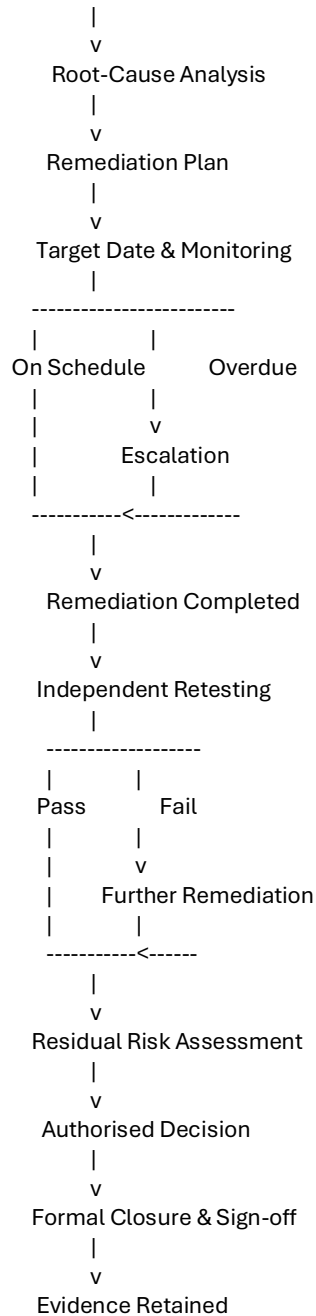
4.1 Control Failure and Remediation Workflow

MDS should use a governed workflow to ensure that control failures are not only identified but also validated, risk-rated, assigned to an accountable owner, remediated, independently retested and formally closed.

Control Failure Workflow

Control Failure / Threshold Breach Detected





Workflow Description

1. Detection and Evidence Capture

A control failure may be identified through the continuous monitoring register, security dashboard, SIEM, vulnerability-management platform, audit activity or another assurance activity. Evidence supporting the failure should be captured and linked to the relevant control.

2. Initial Validation

The monitoring or assurance owner confirms that the exception is genuine and is not caused by incorrect data, a monitoring error or an outdated system record.

3. Risk and Business-Impact Assessment

The issue is assessed based on likelihood, potential impact, affected systems, data exposure, business criticality and existing compensating controls.

4. Assignment

The deficiency is assigned to the accountable control owner, who becomes responsible for developing and implementing the corrective action.

5. Root-Cause Analysis

The control owner determines why the control failed. Possible causes may include technical limitations, inadequate processes, resource constraints, configuration problems or business requirements.

6. Remediation Plan

A corrective action plan is developed with specific actions, owners, resources and target completion dates.

7. Monitoring and Escalation

Progress is monitored against the agreed completion date. Overdue actions are escalated according to their risk level.

8. Independent Retesting

After remediation, an appropriate person independent of the original remediation activity verifies whether the control is now operating effectively.

9. Residual-Risk Decision

Where complete remediation is not possible, the remaining risk must be documented and assessed. An authorised risk owner must decide whether the residual risk can be accepted, transferred, further mitigated or requires additional escalation.

10. Formal Closure

The issue is closed only after remediation evidence has been reviewed, retesting has passed, residual risk has been addressed and the appropriate management authority has approved closure.

4.2 Applied Failure Scenario

Control Deficiency Record

Field	Details
Deficiency ID	MDS-VULN-001
Control	Vulnerability Identification and Remediation
Control Objective	Ensure critical vulnerabilities are remediated within the approved SLA
Detection Source	Monthly vulnerability-management dashboard
Detection Date	Monthly assurance review
Required Target	95% of critical vulnerabilities remediated within SLA
Actual Result	68%
Variance	27 percentage points below target
Overdue Vulnerabilities	12 critical vulnerabilities
Internet-Facing Vulnerabilities	4
Initial Assessment	Confirmed control-performance failure
Primary Control Owner	Infrastructure Manager
Monitoring Owner	Vulnerability Management Lead
Root Cause	Remediation delayed because of application-availability concerns

Risk Rating	High
Business Impact	Increased exposure to exploitation of critical vulnerabilities, particularly on internet-facing systems
Immediate Action	Prioritise assessment and remediation of the four internet-facing critical vulnerabilities
Corrective Action	Develop and execute a prioritised remediation plan for all 12 overdue vulnerabilities
Target Completion	Defined by risk-based remediation plan
Escalation	CISO and relevant senior management
Retesting Method	Vulnerability rescan and validation of remediation evidence
Closure Condition	All required remediation completed or authorised residual risk formally accepted
Evidence Required	Vulnerability scan results, remediation tickets, change records, testing evidence, risk acceptance records where applicable
Status	Open – Remediation Required

4.3 Risk Rating and Escalation

The deficiency should receive a **High** risk rating because:

- The control achieved only **68%** against the approved **95% target**.
- **12 critical vulnerabilities** are overdue.
- **Four vulnerabilities affect internet-facing systems**.
- Delayed remediation is linked to application-availability concerns.
- Continued exposure may increase the likelihood of successful exploitation.

The four internet-facing vulnerabilities should receive immediate prioritisation because they represent externally exposed attack surfaces.

The Infrastructure Manager remains the accountable control owner for remediation. The Vulnerability Management Lead should provide monitoring and reporting, while the CISO should provide oversight and ensure that the deficiency is escalated through the appropriate governance channel.

Where remediation cannot be completed within the required timeframe because of application-availability concerns, the Infrastructure Manager should document the constraint and propose appropriate compensating controls or a formally approved risk treatment decision.

4.4 Remediation Plan

The remediation plan should address the 12 overdue vulnerabilities according to risk and business impact.

Action	Owner	Evidence	Status
Validate all 12 overdue vulnerabilities	Vulnerability Management Lead	Updated vulnerability report	Open
Prioritise four internet-facing vulnerabilities	Infrastructure Manager	Risk-prioritisation record	Open
Assess application-availability constraints	Application / Infrastructure Teams	Technical assessment	Open
Develop remediation schedule	Infrastructure Manager	Approved remediation plan	Open
Implement patches or corrective controls	Infrastructure Team	Change records and technical evidence	Open
Apply compensating controls where immediate remediation is not possible	Security / Infrastructure Teams	Compensating-control evidence	Open
Rescan affected systems	Vulnerability Management Lead	Post-remediation scan	Pending
Review residual risk	Risk / Security Management	Risk assessment	Pending
Approve closure	Authorised Management Owner	Closure approval	Pending

4.5 Retesting Requirements

Remediation should **not automatically result in closure**.

Independent retesting should confirm that:

1. The identified vulnerabilities have been addressed.
2. The remediation was applied to the correct systems.
3. Vulnerabilities are no longer detected or have been reduced to an acceptable state.
4. Security configurations remain compliant.
5. Compensating controls are operating where full remediation was not possible.
6. The original control objective is now being achieved.

For the vulnerability scenario, the primary retesting method should be a **new vulnerability scan or rescan** of the affected systems.

Where necessary, the reviewer should also inspect:

- Change-management records.
- Patch deployment evidence.
- Configuration evidence.
- Application testing results.
- Vulnerability scan results.
- Approved exceptions.
- Compensating-control evidence.

The person performing the retest should be sufficiently independent from the person who performed the remediation to provide objective validation.

4.6 Closure Requirements

The deficiency should only be formally closed when sufficient evidence demonstrates that the corrective action has been completed and independently validated.

Required Closure Evidence

- Updated vulnerability-management report.
- Successful vulnerability rescan.
- Remediation/change tickets.
- Evidence of patch or configuration changes.
- Application testing evidence where availability concerns existed.
- Evidence that the four internet-facing vulnerabilities were addressed.
- Evidence covering the remaining overdue vulnerabilities.
- Approved risk acceptance for any vulnerabilities that cannot be fully remediated.
- Evidence of compensating controls where applicable.
- Independent retesting results.
- Management sign-off.

If full remediation cannot be achieved, the deficiency should **not simply be marked closed**. The remaining risk should be documented and formally accepted by an authorised risk owner or escalated according to MDS's risk governance process.

4.7 Expected Outcome

The proposed workflow ensures that control failures are treated as governed risk issues rather than simply technical tickets. Each deficiency is supported by evidence, assigned to an accountable owner, monitored against a target date, independently retested and formally closed only when sufficient evidence exists.

For the applied vulnerability scenario, the immediate priority is to address the four internet-facing critical vulnerabilities while establishing a controlled remediation plan for all 12 overdue vulnerabilities. The 68% SLA performance should continue to be monitored until the control returns to the approved 95% target or an authorised residual-risk decision is documented.

8. Task 5 Audit Evidence and Assurance Plan (15 marks)

Develop a concise assurance plan that explains how MDS will validate that monitoring evidence is reliable and suitable for management and audit purposes.

5.1 Purpose

The purpose of the assurance plan is to provide MDS with a structured approach for validating that security-control monitoring evidence is sufficient, relevant, reliable and traceable for management and audit purposes. The plan also establishes how evidence will be tested, retained, independently reviewed and followed up when control deficiencies are identified.

5.2 Audit Evidence Standard

For evidence to support an assurance conclusion, it should meet the following criteria:

Criterion	Requirement
Sufficient	Evidence should be adequate to demonstrate whether the control operated as expected.
Relevant	Evidence should directly relate to the control objective, risk and period being assessed.
Reliable	Evidence should originate from a trusted source and have appropriate integrity protections.
Traceable	Evidence should be linked to the control ID, system, owner and relevant monitoring period.
Complete	Required evidence, exceptions and relevant failures should be included.
Timely	Evidence should relate to the period under review.
Authentic	The source and ownership of the evidence should be identifiable.
Protected	Evidence should be protected from unauthorised alteration or deletion.

Before evidence is accepted, the assurance reviewer should confirm that it supports the control objective, covers the required period, identifies its source and owner, includes relevant exceptions, and can be traced back to the originating system or record.

5.3 Sampling and Complete-Population Testing

Sampling may be appropriate where a control operates across a large population and testing every item would not be proportionate. Examples include user-access reviews, security-awareness records, change-management tickets and third-party assurance records.

Complete-population testing is preferable where the population is small, reliable automated data is available, or every exception is significant to the control conclusion. Examples include critical vulnerabilities, critical SIEM log-source coverage, failed backups for business-critical systems and manageable privileged-account populations.

The selected testing approach should be documented and justified.

5.4 Evidence Retention and Protection

MDS should retain assurance evidence in a controlled repository with appropriate access restrictions. Evidence should be linked to the relevant control ID and monitoring period and should identify the evidence source, date and responsible control owner.

Evidence should be protected against unauthorised alteration or deletion, with access restricted according to business need. The original evidence should be preserved where practical, and the relationship between evidence, findings, remediation records and final assurance conclusions should remain traceable.

5.5 Independence of Assurance

MDS should maintain appropriate separation between control operation and control assurance.

The control operator is responsible for operating the control, monitoring performance, maintaining evidence and addressing failures.

The assurance reviewer is responsible for evaluating the evidence, testing control effectiveness, challenging exceptions and performing independent retesting where required.

The individual responsible for operating or remediating a control should not independently approve the effectiveness of their own work or close a deficiency without an appropriate independent review.

Where complete independence is not practical, MDS should use compensating measures such as secondary review, management oversight or periodic independent assessment.

5.6 90-Day Control Assurance Calendar

Period	Priority Assurance Activity	Output
Days 1–15	Critical vulnerability remediation and SLA performance	Vulnerability assurance findings
Days 1–15	MFA and privileged-access monitoring	Access-control findings
Days 16–30	SIEM log-source coverage and security alerts	Logging assurance report
Days 16–30	Endpoint/EDR monitoring	EDR assurance findings
Days 31–45	Backup success and restoration testing	Backup assurance report
Days 31–45	Critical-system patch compliance	Patch assurance findings
Days 46–60	Change-management and emergency changes	Change-control findings
Days 46–60	Cloud security posture monitoring	Cloud-control findings
Days 61–75	Security awareness and phishing resilience	Awareness assurance findings
Days 61–75	Third-party security assurance	Supplier assurance findings
Days 76–85	Follow-up of open deficiencies and overdue remediation	Remediation follow-up report
Days 86–90	Consolidated assurance review	Executive assurance report

Reporting points:

- **Day 30:** Initial assurance findings reported to Security Governance and relevant control owners.
- **Day 60:** Mid-cycle assurance status reported to senior management, including overdue deficiencies.
- **Day 90:** Consolidated assurance report presented to senior management and relevant Board/risk oversight structures.

5.7 Follow-Up and Escalation

Control deficiencies identified through assurance should be assigned to an accountable owner and given a documented remediation action and target date. Progress should be tracked through the control monitoring register.

Overdue or high-risk deficiencies should be escalated according to the defined escalation thresholds. Once remediation is completed, significant deficiencies should undergo independent retesting before formal closure.

5.8 Final Executive Summary

MDS should maintain continuous assurance over its security controls by combining automated monitoring, security telemetry, management review and independent assurance activities.

The key monitoring priorities are:

1. **Critical vulnerability remediation** – particularly overdue and internet-facing vulnerabilities.
2. **Security visibility and monitoring** – ensuring reliable SIEM, endpoint, identity and cloud telemetry.
3. **Access and identity controls** – maintaining MFA coverage and privileged-access reviews.
4. **Backup, patching and recovery** – monitoring backup success, restoration testing and critical-system patch compliance.
5. **Control exceptions and remediation** – ensuring failures are assigned, escalated, remediated and independently retested.

The **first three improvements** management should implement are:

1. Strengthen critical vulnerability remediation

Improve monitoring and escalation for critical vulnerabilities, with priority given to overdue and internet-facing vulnerabilities.

2. Improve evidence quality and traceability

Standardise how monitoring evidence is collected, protected, retained and linked to control IDs, owners and reporting periods.

3. Strengthen independent assurance and follow-up

Establish a structured assurance cycle with independent retesting of significant control failures and formal management reporting of overdue remediation.

5.9 Expected Outcome

The assurance plan provides MDS with a consistent approach for validating the quality of security-control evidence and demonstrating that controls are operating effectively. It also establishes a repeatable 90-day cycle for assurance reviews, management reporting, remediation follow-up and independent retesting.